

Weekly IT Security Brief (Official-source-first) | 2026-06-14 **08:45**

Formatted for readability · Auto-generated

Weekly Summary

- Priority snapshot: 7 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-35273(2026-06-15), CVE-2026-10520(2026-06-14), CVE-2026-11645(2026-06-23). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Turn specs into evals for any agent with ASSERT. Adaptive Spec-driven Scoring for Evaluation and Regression Testing (ASSERT) is an open-source framework for converting natural language behavior requirements into executable evaluations of AI m...
- Threat trend #2: Reconstructing AI activity in investigations. Learn how to investigate AI activity in Microsoft 365 Copilot and Azure AI services using a structured, telemetry-driven approach. This playbook helps security teams reconstruct events, assess dat...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-35273

CVE Title	CVE-2026-35273 oracle/peoplesoft_enterprise_peopletools Unknown Type
CVE Description	Vulnerability in the PeopleSoft Enterprise PeopleTools product of Oracle PeopleSoft (component: Updates Environment Management). Supported versions that are affected are 8.61 and 8.62. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise PeopleSoft Enterprise PeopleTools. Successful attacks of this vulnerability can result in takeover of PeopleSoft Enterprise Pe...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	oracle/peoplesoft_enterprise_peopletools
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-15
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-35273

CVE-2026-10520

CVE Title CVE-2026-10520 | ivanti/standalone_sentry | Remote Code Execution

CVE Description An OS Command Injection vulnerability in Ivanti Sentry before the R10.5.2, R10.6.2 and R10.7.1 versions allows a remote unauthenticated user to achieve root-level remote code execution

Root Cause Unsafe deserialization or input-handling flaws enable arbitrary code execution.

Exploitation Prerequisite Relevant endpoint is exposed and unpatched.

Exploit Path Malicious request/payload -> vulnerability trigger -> remote command execution.

Affected Products ivanti/standalone_sentry

Risk Score 10.0 (CRITICAL)

Exploited in the wild Listed in CISA KEV

KEV remediation due date 2026-06-14

Mitigation Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.

Source <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-10520>

CVE-2026-11645

CVE Title	CVE-2026-11645 google/chrome Unknown Type
CVE Description	Out of bounds read and write in V8 in Google Chrome prior to 149.0.7827.103 allowed a remote attacker to execute arbitrary code inside a sandbox via a crafted HTML page. (Chromium security severity: High)
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	google/chrome, apple/macos, linux/linux_kernel, microsoft/windows
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-11645

CVE-2026-7473

CVE Title	CVE-2026-7473 arista/eos Unknown Type
CVE Description	On affected platforms running Arista EOS where a tunnel decapsulation configuration—such as VXLAN (Virtual Extensible LAN), decap-groups, or a GRE (Generic Routing Encapsulation) tunnel interface—is present, the switch will incorrectly decapsulate and forward other unexpected tunneled packet with a destination IP matching its configured decapsulation IP. This occurs because the switch does not verify the tunnel prot...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	arista/eos, arista/7020sr-24c2, arista/7020sr-32c2, arista/7020srg-24c2, arista/7020tr-48
Risk Score	5.8 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7473

CVE-2026-20245

CVE Title	CVE-2026-20245 cisco/catalyst_sd-wan_manager Unknown Type
CVE Description	A vulnerability in the CLI of Cisco Catalyst SD-WAN Controller, formerly SD-WAN vSmart, Cisco Catalyst SD-WAN Manager, formerly SD-WAN vManage, and Cisco Catalyst SD-WAN Validator, formerly SD-WAN vBond, could allow an authenticated, local attacker to execute arbitrary commands as root by supplying a crafted file to the affected system.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	cisco/catalyst_sd-wan_manager, cisco/sd-wan_vsmart_controller
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-20245

CVE-2026-42271

CVE Title	CVE-2026-42271 litellm/litellm Unknown Type
CVE Description	LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. From version 1.74.2 to before version 1.83.7, two endpoints used to preview an MCP server before saving it — POST /mcp-rest/test/connection and POST /mcp-rest/test/tools/list — accepted a full server configuration in the request body, including the command, args, and env fields used by the stdio transport. When called with a stdio...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	litellm/litellm
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-22
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-42271

CVE-2026-50751

CVE Title	CVE-2026-50751 checkpoint/gaia_os Unknown Type
CVE Description	A logic flow weakness in Remote Access and Mobile Access certificate validation in deprecated IKEv1 key exchange allows an unauthenticated remote attacker to bypass user authentication and establish a remote access VPN connection without a valid user password.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	checkpoint/gaia_os, checkpoint/gaia_embedded, checkpoint/quantum_spark_1530, checkpoint/quantum_spark_1550, checkpoint/quantum_spark_1570
Risk Score	9.3 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-50751



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-11447

CVE Title	CVE-2026-11447 待核實 Unknown Type
CVE Description	A security flaw has been discovered in GL.iNet GL-MT3000 up to 4.4.5. Impacted is the function iwinfo_backend of the file iwinfo.so of the component MTK Backend. The manipulation of the argument device results in command injection. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. Upgrading to version 4.7 is recommended to address this issue. Upgrading the...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-11447

CVE-2026-11448

CVE Title	CVE-2026-11448 待核實 Unknown Type
CVE Description	A weakness has been identified in GL.iNet GL-MT3000 up to 4.4.5. The affected element is the function realpath of the file /rpc of the component Minidlna Service. This manipulation of the argument kube.set causes command injection. The attack is possible to be carried out remotely. Upgrading to version 4.7 is sufficient to fix this issue. It is recommended to upgrade the affected component. The vendor confirms: &qu...
Affected Products	待核實
Risk Score	4.7 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-11448

CVE-2026-11449

CVE Title CVE-2026-11449 | 待核實 | Unknown Type

CVE Description A security vulnerability has been detected in GL.iNet GL-MT3000 4.4.5. The impacted element is the function rpc_sys of the file /cgi-bin/luci/rpc of the component LuCI JSON-RPC Interface. Such manipulation leads to command injection. The attack may be performed from remote. Upgrading to version 4.8.1 is sufficient to resolve this issue. Upgrading the affected component is advised. The vendor confirms: "The issu...

Affected Products 待核實

Risk Score 6.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-11449>

CVE-2026-11450

CVE Title CVE-2026-11450 | 待核實 | Unknown Type

CVE Description A vulnerability was detected in GL.iNet GL-MT3000 4.4.5. This affects the function dlopen in the library /usr/lib/oui-httpd/rpc/ of the component Path Normalization Handler. Performing a manipulation of the argument dev_name results in command injection. It is possible to initiate the attack remotely. Upgrading to version 4.7 mitigates this issue. It is advisable to upgrade the affected component. The vendor confirm...

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-11450>

CVE-2026-11451

CVE Title CVE-2026-11451 | 待核實 | Unknown Type

CVE Description A flaw has been found in GL.iNet GL-MT3000 4.4.5. This impacts the function snprintf of the file /cgi-bin/glc of the component FTP Protocol Handler. Executing a manipulation of the argument media_dir can lead to command injection. It is possible to launch the attack remotely. Upgrading to version 4.8.1 will fix this issue. You should upgrade the affected component. The vendor explains: "In version 4.8.1, before...

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-11451>

CVE-2026-11452

CVE Title CVE-2026-11452 | 待核實 | Unknown Type

CVE Description A vulnerability has been found in GL.iNet GL-MT3000 up to 4.4.5. Affected is the function FUN_0042e200 of the file /cgi-bin/glc of the component SET_USER_PWD Handler. The manipulation of the argument Password leads to command injection. The attack can be initiated remotely. Upgrading to version 4.8.1 is able to address this issue. The affected component should be upgraded. The vendor explains: " The current cod...

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-11452>



Report B: Threat Intelligence News (last 7 days)

Headline: Turn specs into evals for any agent with ASSERT

Source	Microsoft Security Blog
Published	Wed, 10 Jun 2026 16:00:00 +0000
Key Takeaway	Adaptive Spec-driven Scoring for Evaluation and Regression Testing (ASSERT) is an open-source framework for converting natural language behavior requirements into executable evaluations of AI models and agents. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://commandline.microsoft.com/assert-written-intent-executable-evals/

Headline: Reconstructing AI activity in investigations

Source	Microsoft Security Blog
Published	Tue, 09 Jun 2026 17:35:06 +0000
Key Takeaway	Learn how to investigate AI activity in Microsoft 365 Copilot and Azure AI services using a structured, telemetry-driven approach. This playbook helps security teams reconstruct events, assess data exposure, and detect potential threats faster. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/06/09/reconstructing-ai-activity-investigations/

Headline: CISA Issues New Directive Improving How Federal Agencies Prioritize the Mitigation of Cyber Vulnerabilities

Source	CISA News
Published	Wed, 10 Jun 26 12:00:00 +0000
Key Takeaway	CISA Issues New Directive Improving How Federal Agencies Prioritize the Mitigation of Cyber Vulnerabilities Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-issues-new-directive-improving-how-federal-agencies-prioritize-mitigation-cyber-vulnerabilities

Headline: CISA Announces Winners of the 2026 President’s Cup Cybersecurity Competition

Source	CISA News
Published	Tue, 09 Jun 26 12:00:00 +0000
Key Takeaway	CISA Announces Winners of the 2026 President’s Cup Cybersecurity Competition Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-announces-winners-2026-presidents-cup-cybersecurity-competition

Headline: ShinyHunters Targets Education Sector with Oracle PeopleSoft Exploit

Source	Mandiant Blog
Published	Thu, 11 Jun 2026 14:00:00 +0000
Key Takeaway	The activity was observed between May 27, 2026, and June 9, 2026 and is consistent with the exploitation of CVE-2026-35273 , a critical remote code execution vulnerability (CVSS 9.8) in the Environment Management component. The exploitation of this vulnerability directly aligns with the observed tar Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	education/global
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-35273
Link	https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-targets-education-sector-oracle-exploit/

Headline: Seeking Counsel: Ongoing Targeted Campaign Against US Law Firms

Source	Mandiant Blog
Published	Fri, 05 Jun 2026 14:00:00 +0000
Key Takeaway	UNC3753 leverages voice phishing (vishing) and social engineering deception techniques to achieve remote access into corporate environments. Using these compromised personal laptops, they accessed corporate virtual desktop infrastructure (VDI) using native client platforms, such as Windows 365 (Win Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	LockBit
Target	defense/待核實
Technique	T1003.001,T1003.002,T1005
MITRE ATT&CK	T1003.001, T1003.002, T1005, T1020, T1021.001, T1021.004, T1036.005, T1046, T1052.001, T1053.005, T1059.001, T1059.003, T1070.001, T1083, T1133, T1135, T1204.002, T1219, T1486, T1547.001, T1553.002, T1562.001, T1566.004, T1567.002, T1569.002, T1572
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/targeted-campaign-us-law-firms/

Headline: A tale of two eras

Source Cisco Talos Blog

Published Thu, 11 Jun 2026 18:00:49 GMT

Key Takeaway In this week's newsletter, Amy reminisces on the tech toys of their childhood, inspired by a hilarious lesson about why your digital privacy shouldn't be left on an open channel. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/a-tale-of-two-eras/>

Headline: Microsoft Patch Tuesday for June 2026 — Snort rules and prominent vulnerabilities

Source	Cisco Talos Blog
Published	Tue, 09 Jun 2026 21:21:00 GMT
Key Takeaway	Microsoft Patch Tuesday for June 2026 — Snort rules and prominent vulnerabilities Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/microsoft-patch-tuesday-for-june-2026-snort-rules-and-prominent-vulnerabilities/

Headline: Critical Splunk Enterprise Flaw Lets Attackers Run Code Without Authentication

Source	The Hacker News
Published	Sat, 13 Jun 2026 18:53:03 +0530
Key Takeaway	Splunk has released security updates to address a critical security flaw in Splunk Enterprise that could be exploited to conduct unauthenticated file operations and even remote code execution. The vulnerability, tracked as CVE-2026-20253, is rated 9.8 on the CVSS scoring system. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-20253
Link	https://thehackernews.com/2026/06/critical-splunk-enterprise-flaw-lets.html

Headline: U.S. Orders Anthropic to Suspend Fable 5 and Mythos 5 Access for Foreign Nationals

Source	The Hacker News
Published	Sat, 13 Jun 2026 11:12:50 +0530
Key Takeaway	Anthropic said on Friday it will "abruptly disable" its most advanced artificial intelligence (AI) models, Claude Fable 5 and Mythos 5, for all users after the U.S. government ordered it to suspend access to the models for foreign nationals, whether inside or outside the U.S., citing national security Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/l...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/06/us-orders-anthropic-to-suspend-fable-5.html

Headline: NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks

Source	SecurityWeek
Published	Sat, 13 Jun 2026 15:52:58 +0000
Key Takeaway	By default, npm install will no longer execute scripts from dependencies, unless explicitly allowed. The post NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/npm-12-will-change-script-execution-behavior-to-prevent-supply-chain-attacks/

Headline: Anthropic Says It Has Taken Its Latest AI Models Offline to Comply With New Export Controls

Source	SecurityWeek
Published	Sat, 13 Jun 2026 06:38:34 +0000
Key Takeaway	Anthropic takes Fable 5 and Mythos 5 offline to comply with a directive from the Trump administration to prevent use by foreign nationals. The post Anthropic Says It Has Taken Its Latest AI Models Offline to Comply With New Export Controls appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/anthropic-says-it-has-taken-its-latest-ai-models-offline-to-comply-with-new-export-controls/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)